

1. Remediation (Fix Using Principle of Least Privilege)

The vulnerability was mitigated by applying the Principle of Least Privilege, ensuring that the IAM user only retains permissions necessary for its intended role.

The following corrective actions were implemented:

✓ Policy Hardening

The custom policy Insecure-IAM-Policy was modified to remove all IAM management permissions, including:

- iam:CreateAccessKey
- iam:AttachUserPolicy
- iam:PassRole

✓ Permission Restriction

The IAM user was restricted to minimal or non-sensitive permissions only, ensuring it cannot modify its own identity or credentials.

✓ Access Control Enforcement

After applying the fix, the user was tested using AWS CLI to confirm restrictions. Attempts to perform IAM operations such as access key creation resulted in AccessDenied, confirming successful mitigation.

2. Verification of Fix

Post-remediation testing was conducted using AWS CLI commands:

- Attempts to create access keys were denied.
- IAM modification actions were blocked.
- The user retained only limited, non-administrative access.

This confirms that the misconfiguration has been successfully resolved and the system now enforces proper security boundaries.

3. Conclusion

The initial IAM configuration introduced a significant security risk due to excessive permissions granted to a non-privileged user. Through simulation, it was demonstrated that these permissions could enable credential abuse and potentially lead to privilege escalation in a real-world scenario.

By applying the Principle of Least Privilege and removing unnecessary IAM permissions, the environment was successfully secured. This significantly reduced the attack surface and ensured that the IAM user operates within strictly defined boundaries.